

LockTalk

Medium

1. Overview

The web page is very simple, only have a 3 api requests!

LockTalk API: The Ransomware Dystopia

An API facilitating negotiation attempts between companies and ransomware groups in a dystopian world.

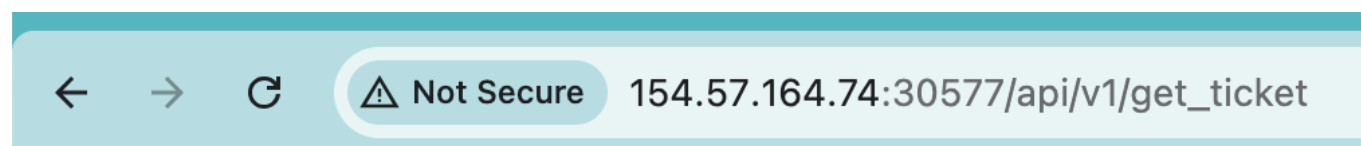
Available API Endpoints

GET	/api/v1/get_ticket	Generates a ticket (JWT token) 🔒	Execute
GET	/api/v1/chat/{chatId}	Find chat history by ID	Enter JWT Token Enter Chat ID [1-10] Execute
GET	/api/v1/flag	Retrieves the flag 🔒	Enter JWT Token Execute

Response body

Begin by executing an API endpoint!

I try `get_ticket`, which is the only API I can use without JWT token! But the server rejects this request!



403 Forbidden

Request forbidden by administrative rules.

I read the source code to understand how do server reject my request. In `haproxy.cfg` file, the server rejects all request with exactly string `/api/v1/get_ticket`, so I search with key word `bypass path_beg` and find the `funny bypass` with `//` for `/`, yeah, this is the same for the web server, start with root direct page! So I try to request with `//api/v1/get_ticket`. Boom!! I have a token!!

```
{ "ticket":
    "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.ejYleHAiOjE0e3NzcYMTc2ODGsImldhCI6MTc3ZnIwODA0CwianRpIjoifSZF4dEtKcjVpalVYTvo1VUVrM0RYQSIsIm5iziI6MTc3ZnIwODA0Cwicm9sZSI6ImldlXN0iwiidXNlcii6ImldlXN0ZXNoZWxkaXN0ZXQ7D0t09tkPtMrYh8ehKGPOi8g8fJEMUpzp6-5EjNyIf_6ZM4fBK_mf9Ugd4MFpZdcdpnxni6hCR4gs441UbAcKwp4E4MJURi8-vDZKn7KuPz-ZePKUR0f8giYzyVyRKJgT6ak6zo_GH1BncFeoksFTalwj_XVKv5XwQfabTi_X3kxW0t7iu8oz_heQgtPYJBxCyX6wr4vGsx20PmX6pIbamypAyp-2IBJKGVU0R0w9Iew6GU4QxiIw05WmnHkPaFiAv35FnZa3l_ZhNoGuDu0zmMM5kc0062iK8eqWZ-qCEB0jsELAKeZLxcRt8p_et0Imw0p-w6V7-LqbEaf00q"} }
```

Reading a source code, I can get flag if my token role is **administrator**. I think the core vector is **JWT** attack. I search about python-jwt vulnerabilities and I find it!



<https://github.com> › [advisories](#) · [Dịch trang này](#)

21 thg 9, 2022 — The issue is caused by an inconsistency between the **JWT** parsers used by **python-jwt** and its dependency jwcrypto. By mixing compact and JSON ...



<https://nvd.nist.gov> › [vuln](#) › [CVE-202...](#) · [Dịch trang này](#)

23 thg 9, 2022 — **python-jwt** is a module for generating and verifying JSON Web Tokens. Versions prior to 3.3.4 are subject to Authentication Bypass by Spoofing.



<https://www.vicarius.io> › [posts](#) › [authentic leadership](#) · [Dịch trang này](#)

15 thg 7, 2024 — This vulnerability, when exploited, **allows an attacker to create a valid JWT** without using the secret key, modify the payload of the JWT to ...



<https://www.sentinelone.com> › [cve-20...](#) · [Dịch trang này](#)

17 thg 2, 2026 — **CVE-2022-39227 is an authentication bypass vulnerability in Python-jwt that allows attackers to forge JWT contents and spoof identities without ...**



<https://security.snyk.io> › ... › [python-jwt](#) · [Dịch trang này](#)

Exploiting this vulnerability might result in spoofing other users' identities, hijacking users' sessions, or bypassing authentication. How to fix Improper ...

The root cause of this vulnerability is `python-jwt` process special token format and make this is correct token with old signature and custom data from user! Let reading the `requirements.txt` file, the version of `python-jwt` is `3.3.3`. Yeah, now we exploit it!

